

WEB VAPT EVIDENCE FILE DOCUMENTATION

16-stored-xss-payload-source.png

Field	Details
Project	Enterprise Security Assessment Lab
Module	Sub-Project 1 - Web Application VAPT
Evidence Row	22 - Stored XSS
Evidence File	16-stored-xss-payload-source.png
Result Type	Stored payload evidence
Prepared For	GitHub portfolio documentation

Document Purpose

This PDF documents one specific evidence file from the Web VAPT evidence table. It embeds the actual screenshot, explains what the screenshot proves, maps it to the methodology, and records professional interpretation, risk, remediation, and redaction guidance for GitHub publication.

1. Embedded Evidence Screenshot

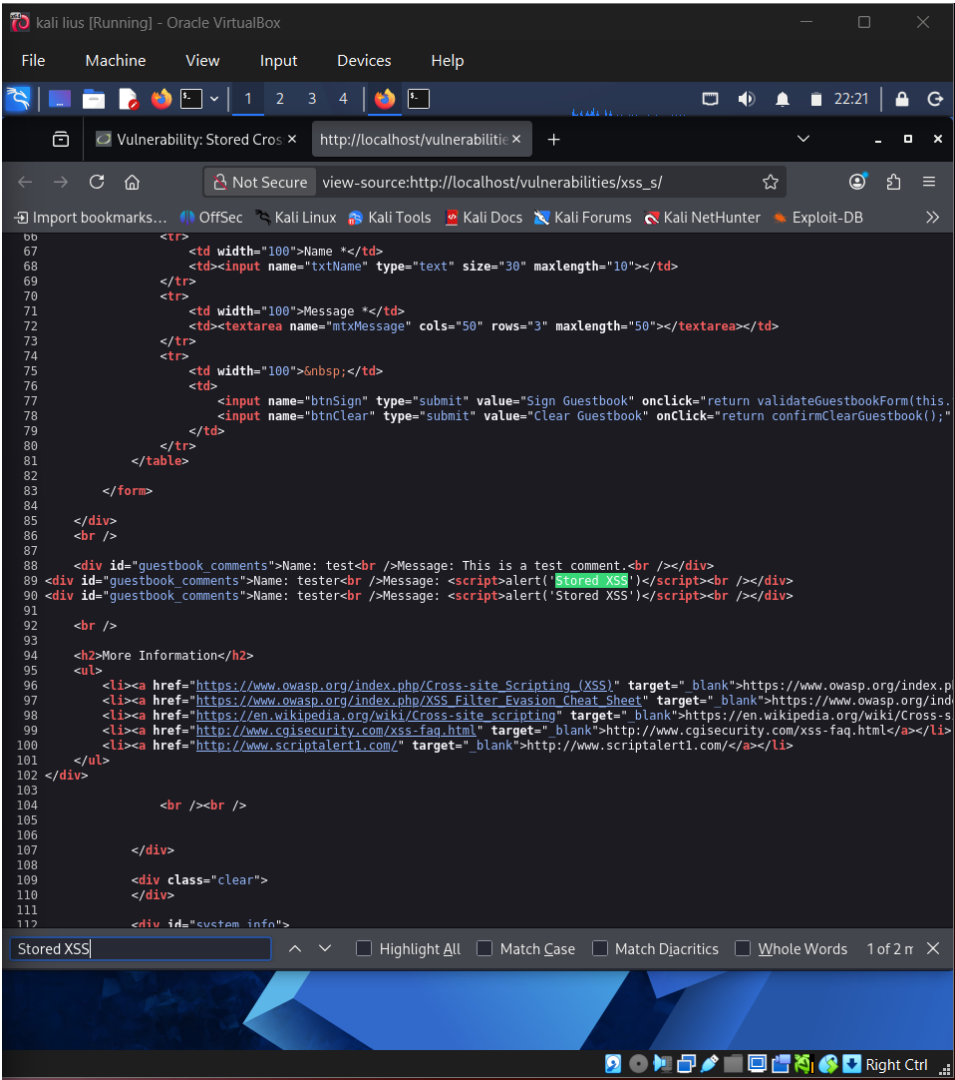


Figure 1 - Actual screenshot evidence: 16-stored-xss-payload-source.png

What this screenshot proves

The screenshot shows stored script payloads present in the page source/output, demonstrating persistent XSS in the lab.

2. Evidence Context

Area	Value
Testing Phase	Stored Cross-Site Scripting Validation
Tool / Component	Browser source view / DVWA
Objective	Validate that an XSS payload was stored and rendered by the application.
Result Type	Stored payload evidence

3. Command / Workflow Used

```
Payload: <script>alert("Stored XSS")</script>
Submit payload in stored XSS guestbook/comment field
View page source or rendered output
```

The commands or workflow above represent the evidence-producing action. Placeholders such as , , or should be used in public documentation instead of live secrets or private infrastructure details.

4. Professional Interpretation

The screenshot shows stored script payloads present in the page source/output, demonstrating persistent XSS in the lab.

This evidence should be treated as a supporting artifact, not as a standalone finding by itself. In a professional report, the screenshot supports a specific testing phase, validates an observation, and strengthens reproducibility when paired with methodology and remediation guidance.

5. Security Risk / Why It Matters

Stored XSS can affect every user who views the impacted page, including administrators.

For this portfolio project, the risk is described in a real-world context while clearly noting that the target was an authorized DVWA/local lab environment. This avoids exaggerating lab results as production impact.

6. Recommended Remediation / Defensive Control

Sanitize stored input, encode output on render, deploy CSP, and use safe templating.

7. GitHub Redaction Requirements

Comments containing private data, session values, user identifiers, and sensitive URLs.

Before pushing to GitHub, confirm that screenshots do not expose cookies, session IDs, credentials, hashes, cracked passwords, private IPs, internal file paths, or any secret values. If the screenshot already contains sensitive information, blur or crop it before upload.

8. GitHub README Link Snippet

```
[Open Evidence PDF](./reports/evidence-file-documentation-with-screenshots/22_16-stored-
xss-payload-source_evidence_documentation.pdf)
```

Legal and Ethical Note

This evidence documents authorized testing against an intentionally vulnerable local lab target. The techniques described must not be used against public or third-party systems without explicit permission.